PENSE-BÊTE · DROIT ET STATUT

Règlement Cybersécurité des produits numériques

01-10 CRA - Règlement européen Cybersécurité des produits numériques — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le règlement encadre les produits dont l'utilisation prévue comprend une connexion directe ou indirecte, logique ou physique, à un dispositif ou à un réseau.
2. Les fabricants doivent assurer une assistance minimale de 5 ans et conserver la documentation pendant 10 ans ou la durée d'assistance.
3. Les vulnérabilités exploitées et les incidents graves doivent être notifiés à l'ENISA et au CSIRT coordinateur via une plateforme unique.

Objet et périmètre du règlement

Notion	À retenir
Objet du règlement	Établit des règles pour la mise à disposition de produits avec **éléments numériques** afin de garantir leur **cybersécurité**.
Champ d'application	Produits dont l'utilisation prévue comprend une **connexion directe ou indirecte**, **logique ou physique**, à un **dispositif** ou à un **réseau**.
Exclusions	Dispositifs médicaux (et in vitro), véhicules à moteur, aviation civile, équipements marins ; produits **sécurité nationale/militaire** ou **informations classifiées** ; logiciels libres hors **activité commerciale**.

Obligations des opérateurs économiques

Notion	À retenir
Fabricants	Conception selon **annexe I** ; évaluation des risques documentée ; assistance minimale **5 ans** ; mises à jour et documentation conservées **10 ans** ou durée d'assistance.
Importateurs et distributeurs	Importateurs : vérifier conformité et évaluation. Distributeurs : vérifier **marquage CE** et instructions. **En cas de risque** : ne pas mettre sur le marché et informer fabricant/autorités.
Intendants logiciels ouverts	Mettre en place **politique de cybersécurité** ; coopérer avec autorités ; signaler **vulnérabilités exploitées** et **incidents graves** affectant réseaux/systèmes.

Gestion des vulnérabilités et signalement

Notion	À retenir
Processus de signalement obligatoire	Vulnérabilité **activement exploitée** ou incident grave → **ENISA** + **CSIRT coordinateur** (plateforme unique) : alerte précoce **24 h**, notification **72 h**, rapport final (1 mois pour un incident).
Gestion des vulnérabilités et transparence	**SBOM** ; correction sans retard par **mises à jour de sécurité**, séparées des fonctionnalités **si techniquement possible** ; tests réguliers ; **divulgation coordonnée**.

Conformité et exigences essentielles

Notion	À retenir
Exigences de sécurité	Livraison sans **vulnérabilité exploitable connue**, configuration **sécurisée par défaut**, protection **confidentialité/intégrité** (chiffrement), protection **accès non autorisés**, limitation **surfaces d'attaque** et **disponibilité** (résilience **déni de service**).
Procédures d'évaluation	**Standard** : `Module A`. **Classe I** : normes harmonisées + `Module A`, ou `Module B+C`, ou `Module H`. **Classe II** : tiers obligatoire (B+C, H) ou certification européenne. **Critiques** : certification si acte délégué.
Marquage CE et déclaration	Marquage **CE** : **visible, lisible et indélébile** sur produit ou emballage. **Déclaration UE de conformité** : obligatoire pour attester les exigences essentielles ; version **simplifiée** autorisée avec **lien internet** vers le texte complet.

Surveillance et sanctions

Notion	À retenir
Surveillance et gouvernance	**ADCO** assure l'application uniforme ; **ENISA** gère la plateforme de signalement ; la **Commission** intervient via des mesures correctives.
Sanctions et pénalités	Amendes : **15M€ / 2,5% CA** (exigences essentielles), **10M€ / 2% CA** (autres obligations), **5M€ / 1% CA** (infos inexactes).

Calendrier et mesures de soutien

Notion	À retenir
Calendrier d'application	Entrée en vigueur : **20e jour** suivant publication. Applicabilité : **11 décembre 2027** (**36 mois** après entrée en vigueur). Signalement vulnérabilités/incidents : **11 septembre 2026**. Notification organismes évaluation : **11 juin 2026**.
Mesures de soutien	États membres soutiennent **microentreprises** et **PME** (**formations**, **sas réglementaires** pour produits innovants). **Documentation technique simplifiée** possible pour **microentreprises** et **petites entreprises**.

Pièges et confusions

- ⚠ Confondre la durée minimale de support de 5 ans avec une durée fixe immuable (elle peut être ajustée selon la durée de vie prévue du produit).
- ⚠ Croire que les mises à jour de sécurité peuvent être payantes (elles doivent être fournies gratuitement).
- ⚠ Croire que les normes harmonisées sont obligatoires : leur respect confère une **présomption de conformité**.
- ⚠ Oublier qu'une modification substantielle d'un produit nécessite une nouvelle évaluation de conformité.

Sigles et définitions

Produit comportant des éléments numériques	Tout produit logiciel ou matériel et ses solutions de traitement de données à distance, y compris les composants mis sur le marché séparément.
Traitement de données à distance	Tout traitement pour lequel le logiciel est conçu par le fabricant et dont l'absence empêcherait le produit d'exécuter une de ses fonctions.
Vulnérabilité exploitable	Faiblesse ou faille susceptible d'être utilisée efficacement par un adversaire en conditions de fonctionnement effectives.
Période d'assistance	Durée au cours de laquelle un fabricant est tenu de garantir que les vulnérabilités sont traitées efficacement.
SBOM	Nomenclature des logiciels contenant les détails et les relations avec la chaîne d'approvisionnement des composants.
Intendant de logiciels ouverts	Personne morale fournissant un soutien systématique au développement de produits logiciels libres et ouverts destinés à des activités commerciales.
Produit important	Produit dont la fonctionnalité comporte un risque de cybersécurité élevé, classé en classe I ou II.
Produit critique	Produit dont la fonctionnalité présente un risque systémique élevé, listé à l'annexe IV.

Auto-test

1. Quelle est la durée de conservation de la documentation par le fabricant ?
2. Quel est le délai pour l'alerte précoce lors d'un signalement ?
3. Quel est le montant maximum de l'amende pour non-respect des exigences essentielles ?
4. À quelle date l'applicabilité du règlement est-elle prévue ?
5. Quel organisme gère la plateforme de signalement ?

Réponses : **1.** 10 ans ou la durée d'assistance. · **2.** Sous 24 heures. · **3.** 15M€ / 2,5% CA. · **4.** 11 décembre 2027. · **5.** ENISA.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.